Script-Controlled ACL – Restrict Record Access Based on Field Value

*

Brainstorming & Ideation Phase :*

Introduction:

The Brainstorming and Ideation Phase is the initial and most important stage of the project. In this phase, team members discuss various security issues in Service Now tables. The main focus is to understand how Access Control List (ACL) works and how we can use a script inside ACL to restrict records based on a particular field value, such as Department, Branch, or Location.

Problem Identification:

1. By default in Service Now, if a user has access to a table, they can see all records in that table.

2. In our Institution Details table, ECE branch records are visible to all users, including CSE, MECH etc. This is a data privacy issue.

3. Role-based ACL alone cannot solve this, because the restriction is not based on role, but based on the value stored in the `branch` field.

4. There is a need for a dynamic security model that checks `current. Branch` value at runtime.

Idea Generation:

During brainstorming, we identified two types of solutions:

- *Normal ACL:* Allow/Deny based on role only.

- *Script-Controlled ACL:* Allow/Deny based on script logic + field value.

We decided Script-Controlled ACL is the best solution. In this, we will create a Record-level ACL on `u_institution_details` table with Operation as `read`. Inside the ACL script, we will check if `current. Branch == 'ECE'` and if the logged-in user belongs to `ECE Department` group, then only `return true`.

Main Objective:

The main objective of this idea is to:

- Restrict record access based on field value.

- Ensure only authorized department staff can view their department records.

- Improve data confidentiality and maintain department-wise security.

- Avoid unauthorized modification or deletion of other department data.

Concept of Scripted ACL:

A Scripted ACL is an ACL where the `Script` checkbox is enabled. The system executes the script for every record access. The script uses two important objects:

- `current`: Refers to the record being accessed (e.g., `current. Branch`)

- `sightseer()`: Refers to the logged-in user to check role

If the script returns `true`, access is allowed. If it returns `false`, access is denied and the record will not be visible.

Expect outcome

After implementing this Script-Controlled ACL, the system will provide field-value based security. It will prevent data leakage between departments, improve security compliance, and make the application more secure and reliable. This approach can be extended to other fields like Location, Company, etc.

Perfect outcome:

The proposed solution is a Script-Controlled Record ACL. The ACL checks the value of the Branch field before allowing a user to read the record. The user's group or department is compared with the branch value stored in the record.

If the required condition is satisfied, access is granted. If the condition is not satisfied, access is denied. This ensures that users can view only the records relevant to their department.

The solution can be implemented without changing the existing table structure. It can also be extended to other operations such as Create, Write and Delete after successful testing.

Conclusion:

The Script-Controlled ACL project demonstrates how Service Now security features can be used to implement field value based record access. Through brainstorming, ideation and analysis, a suitable approach was identified for restricting records according to branch or department values.

The proposed solution provides a flexible method of controlling access without requiring major changes to the application. The concept can also be reused for different tables and business requirements.

Overall, this project provides a clear understanding of ACLs, record-level security, scripting and condition-based access control in Service Now.